UNIT 3 · TOPIC 3.1

Network Vulnerabilities and Attacks

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. A network administrator notices that devices on the local area network are forwarding traffic to an attacker-controlled machine instead of the legitimate default gateway. Which type of network attack is most likely responsible?

- ○ A. DNS amplification
- ○ B. Port scanning
- ○ C. Ping flood
- ○ D. ARP poisoning

2. Which term correctly describes the estimated severity of harm that would result if a network threat were successfully exploited?

- ○ A. Threat likelihood
- ○ B. Attack vector
- ○ C. Risk impact
- ○ D. Vulnerability window

3. Which of the following best distinguishes a Distributed Denial of Service (DDoS) attack from a standard Denial of Service (DoS) attack?

- ○ A. DDoS attacks target network-layer protocols, while DoS attacks target application-layer protocols.
- ○ B. DDoS attacks require physical access to the target network, while DoS attacks are carried out remotely.
- ○ C. DDoS attacks originate from multiple coordinated sources, while DoS attacks originate from a single source.
- ○ D. DDoS attacks always result in permanent data loss, while DoS attacks only cause temporary outages.

4. A hospital uses an unencrypted guest Wi-Fi network that shares the same broadcast domain as its internal clinical network. A security analyst is evaluating network risks. Which assessment best describes the likelihood and impact of a packet-sniffing attack on this configuration?

- ○ A. Low likelihood and low impact, because packet sniffing requires physical access to network hardware.
- ○ B. High likelihood and high impact, because sniffing unencrypted wireless traffic can expose patient data to any nearby attacker.
- ○ C. High likelihood and low impact, because traffic captured on a guest network contains only public-facing data.
- ○ D. Low likelihood and high impact, because specialized hardware is required to intercept wireless signals.

5. At Adams County Hospital, an attacker on the internal network launches an ARP spoofing attack targeting communication between nurse workstations and the patient-records file server. Which of the following correctly evaluates the impact of this attack?

- ○ A. The impact is high because the attacker can intercept or alter patient records transmitted between the workstations and the file server.

○ B. The impact is minimal because ARP spoofing only affects internet-facing traffic, not internal server communication.

○ C. The impact is moderate because ARP spoofing is detected and blocked automatically by the web application firewall.

○ D. The impact is low because the file server's TLS encryption prevents captured packets from being read.

6. A security analyst at Adams County Hospital is evaluating two risks for the public appointment-booking web server: (1) IP spoofing to bypass access control lists, and (2) a volumetric DDoS attack. The server sits behind a stateful firewall. Which evaluation of these two risks is most accurate?

○ A. IP spoofing has higher likelihood than DDoS because stateful firewalls do not inspect source addresses.

○ B. Both threats carry equal likelihood because the firewall processes both at the packet level in the same way.

○ C. DDoS has higher likelihood and comparable overall risk, because stateful firewalls significantly mitigate IP spoofing but cannot alone stop volumetric flood traffic.

○ D. Neither risk is significant because the appointment-booking server does not store sensitive data.

7. A hospital security team assesses a compound attack in which an adversary first performs ARP poisoning to position themselves as a man-in-the-middle, then uses packet sniffing to extract credentials from unencrypted HTTP sessions on the clinical network. Which evaluation of this compound threat's overall risk is most accurate?

○ A. The compound risk is greater than either individual threat evaluated in isolation, because successful ARP poisoning dramatically raises the likelihood that sniffing will yield high-value credentials.

○ B. The compound risk is equivalent to ARP poisoning alone, since sniffing only becomes useful if the first stage succeeds.

○ C. The compound risk is lower than either individual attack because multi-stage attacks are more complex to execute and therefore less likely to succeed.

○ D. The compound risk is equivalent to sniffing alone because overall risk is determined solely by what data is exposed, not by the method used to reach it.

8. A hospital CISO is choosing between two approaches to evaluate the likelihood and impact of network attacks: (A) an AI-powered threat intelligence platform that continuously scans logs and CVE feeds and auto-scores risks, and (B) quarterly manual risk assessments conducted by the security team. Which evaluation of these two approaches is most complete?

○ A. Approach A is strictly superior because AI eliminates human subjectivity from risk evaluation.

○ B. Approach B is strictly superior because risk evaluation requires organizational judgment that AI cannot provide.

○ C. Both approaches yield equivalent risk evaluations as long as both use the same CVE data as their source.

○ D. Approach A provides higher timeliness and threat coverage but may generate false positives and lacks organizational context; Approach B provides deeper contextual judgment but may miss rapidly emerging threats between quarterly cycles. A hybrid approach maximizes both coverage and accuracy.

9. A hospital security committee must prioritize remediation between two identified network risks: Risk X, a known vulnerability in the web application's authentication module (CVSS 7.2, patient-facing, external exposure) and Risk Y, outdated firmware on internal network switches enabling VLAN hopping (CVSS 6.4,

internal network segmentation breach). Analyst capacity allows full remediation of only one risk this quarter. Which prioritization framework is most defensible?

- ○ A. Apply a likelihood × impact analysis incorporating organizational context, including data sensitivity, regulatory exposure, existing compensating controls, and exploitability in the current environment, before assigning priority.
- ○ B. Prioritize Risk Y solely because VLAN hopping could expose the entire internal network.
- ○ C. Prioritize Risk X solely because its CVSS score is numerically higher.
- ○ D. Defer both risks to the next quarterly review cycle since neither has a critical-severity CVSS score above 9.0.

10. Which of the following is a standard component of a risk register used to document network security risks?

- ○ A. Source code for network monitoring scripts
- ○ B. A list of approved vendor contracts
- ○ C. The likelihood and impact rating for each identified risk
- ○ D. Network topology diagrams from the previous fiscal year

11. A cybersecurity analyst writes the following: "If an attacker successfully executes a DNS spoofing attack on the hospital's public-facing booking server, patients could be redirected to a fraudulent site that harvests their payment credentials." This statement is best identified as which component of risk documentation?

- ○ A. Risk impact statement
- ○ B. Risk likelihood statement
- ○ C. Risk treatment plan
- ○ D. Residual risk record

12. Which of the following best describes the primary purpose of formally documenting network security risks in a risk register?

- ○ A. To enable consistent, informed decision-making about risk prioritization and treatment across the organization
- ○ B. To provide a legal defense in the event of a data breach lawsuit
- ○ C. To satisfy software licensing requirements for security monitoring tools
- ○ D. To eliminate the need for technical controls by making risks visible to leadership

13. A network security analyst at Adams County Hospital has confirmed that the hospital's internal network is vulnerable to ARP poisoning due to the absence of Dynamic ARP Inspection on the switches. What information should the analyst document in the risk register for this finding?

- ○ A. The IP addresses of every device on the affected network segment
- ○ B. The likelihood of the attack, its potential impact on patient data confidentiality and availability, and recommended mitigations such as Dynamic ARP Inspection
- ○ C. A full packet capture demonstrating a proof-of-concept ARP poisoning attack
- ○ D. The vendor name, model number, and purchase date of each network switch on the segment

14. A hospital security team must communicate a newly discovered network vulnerability to two separate audiences: (1) the IT security team responsible for remediation, and (2) hospital administrators who hold budget authority but have no technical background. Which risk documentation approach best serves both audiences?

- ○ A. Produce a technical risk register entry for the IT team and a separate executive summary translating risk into operational and business impact language for administrators.

○ B. Produce a single plain-language summary using only business impact language, distributed to both audiences.

○ C. Produce a single highly technical report using protocol-level terminology and CVSS scores, distributed to both audiences.

○ D. Communicate risk findings only through verbal briefings to avoid written documentation being misinterpreted by non-technical administrators.

15. After identifying a volumetric DDoS risk on the hospital's public booking server, the security team implements rate-limiting rules on the perimeter firewall. Before marking the risk register entry as closed, which documentation step is required?

○ A. Document the residual risk, the remaining likelihood and impact of DDoS after the rate-limiting control, and record the control as implemented with its implementation date.

○ B. Delete the original risk entry since the control has been successfully implemented.

○ C. Escalate to the CISO for written sign-off before making any changes to the risk register entry.

○ D. Create a new, separate risk entry for residual risk while leaving the original entry unchanged and open.

16. A hospital security analyst documents a network risk as follows: "Risk: ARP poisoning. Likelihood: High. Impact: High." The analyst marks the entry complete. Which evaluation of this documentation practice is most accurate?

○ A. The documentation is complete because likelihood and impact are the two core components of risk evaluation.

○ B. The documentation is incomplete only because it lacks a CVSS severity score for the vulnerability.

○ C. The documentation is incomplete because it omits the risk owner, affected assets, recommended mitigations, and residual risk, all of which are required for an actionable risk register entry.

○ D. The documentation is complete and appropriately brief; risk registers should avoid excessive detail to prevent information overload.

17. A hospital CISO is evaluating whether to use an AI-powered vulnerability scanner that auto-populates risk register entries from CVE feeds and log analysis, or to rely on manual analyst documentation of network risks after each assessment. Which evaluation of these two documentation approaches is most complete?

○ A. AI-generated entries are always preferable because they eliminate human subjectivity and bias from risk documentation.

○ B. Manual documentation is always preferable because risk registers require organizational judgment that AI is incapable of providing.

○ C. AI-generated entries offer speed and coverage but require analyst validation for accuracy and organizational context; manual entries are more contextually accurate but do not scale and leave gaps between assessment cycles. A hybrid approach combining both maximizes both coverage and documentation quality.

○ D. The documentation method is irrelevant provided both approaches populate the same fields, likelihood, impact, and mitigation, in the register.

18. A hospital security team simultaneously identifies three network risks: (1) ARP poisoning vulnerability on the internal LAN, (2) a volumetric DDoS exposure on the public web server, and (3) an outdated TLS configuration on the patient-records file server. Analyst capacity is limited. Which risk documentation and prioritization strategy is most defensible from a risk management standpoint?

○ A. Document all three risks with equal priority since simultaneous identification requires equal treatment in the register.

○ B. Document all three risks fully in the register, then apply a likelihood × impact matrix incorporating organizational context to assign priority, scheduling review dates for lower-priority items to ensure they are not neglected.

○ C. Document only the highest-impact risk to avoid overwhelming the risk register with entries during a capacity-constrained period.

○ D. Escalate all three risks immediately to external security consultants since simultaneous identification indicates a systemic failure exceeding internal capacity.